

Forward

Business leaders face intense pressure to rapidly adopt and scale artificial intelligence initiatives to capitalize on the promise of AI to drive innovation, enhance decision-making, optimize efficiencies and streamline operations. This push for rapid AI adoption brings a significant challenge: how to successfully apply AI to business use cases while managing the complex risks associated with security, compliance and privacy. However, the lack of a clear AI risk management strategy can hamper adoption and stall innovation.

AI remains uncertain because it continuously changes in advancements and deployment approaches, causing business leaders to slow adoption. Yet pausing AI adoption to gain more clarity will put businesses in the precarious position of falling behind industry leaders and losing customers. Organizations must take on AI while minimizing risk, maintaining compliance and ensuring privacy.

AI systems can be complex, and at the same time, AI can introduce an array of vulnerabilities that may be exploited by bad actors, leading to data breaches, model manipulation and non-compliance with regulatory requirements. Many AI security systems amount to a list of controls, with little recognition of business context and no ability to adapt depending on the underlying risk in question. They also lack the flexibility needed to mitigate evolving risks associated with AI, such as data quality issues and model drift. All of this leads to ineffective risk management, increased risk exposure and slowed AI adoption.

Business leaders now more than ever need actionable guidance on how to protect environments and remain compliant without stalling AI innovation and growth with outdated or overly complex security standards that are security-centric and not business-centric.

Enter the Databricks AI Security Framework (DASF). With input from dozens of experts in the GenAI and ML community, the DASF helps business leaders understand the canonical components of AI systems and the risks associated with each. It breaks down AI systems to their foundational elements, focusing teams on the most relevant threats and helping them implement applicable mitigations.

As detailed on the pages that follow, the DASF outlines seven straightforward steps that guide business leaders through the process of securing AI within their organizations. They include guidance on the importance of understanding AI models and the people and processes involved in building and managing AI systems. The steps also cover the risks and threats associated with various deployment models and use cases, as well as the controls required to mitigate them.

The DASF represents an actionable roadmap for business leaders to follow in securing their AI systems. Because the DASF continuously aligns with industry standards, business leaders can be confident that their organizations are meeting regulatory requirements and staying ahead of emerging threats.

AI governance is far more than simply a compliance checklist item, however. Rather, fully embracing governance is a key enabler of future-ready innovation. Viewed in that light, addressing AI governance becomes an opportunity. An effective AI governance framework allows organizations to fully embrace AI initiatives with confidence and peace of mind that their AI implementations are secure and scalable.

This eBook provides an executive overview of DASF and its role in AI adoption and governance. (A more comprehensive DASF guide is [available here](#).) The intent is to empower business leaders with the roadmap, best practices and tools they need to create secure, scalable and flexible AI systems that drive innovation and growth.

Seven steps for managing AI risks

Companies need a simplified way to manage AI risks and stay aligned with business priorities. That requires collaboration among business, data, AI, governance and security teams to navigate this balancing act and innovate without conflict. More to the point, they need to understand and identify the risks relevant to their AI use cases instead of getting bogged down analyzing all the possible threat scenarios viewed through the lens of security standards built for a deterministic pre-AI world.

We propose seven steps to simplify the management of AI risks:

- 1 Have a **mental model of an AI system** and the components that need to work together.
- 2 Understand the **people and processes** involved in building and managing AI systems and define their roles.
- 3 Understand what responsible AI entails and **all the likely AI risks** and catalog those risks across the AI components.
- 4 Understand the various **AI deployment models** and risk implications for each.
- 5 Understand the unique **threats to your AI use cases** and map your risks to those AI threats.
- 6 Understand the **unique risks that apply to your AI use case** and filter for those risks based on your use cases.
- 7 **Identify and implement controls** that need to be applied per your use case and deployment model, mapping each risk to AI components and controls.

An open framework for AI security

Databricks worked with dozens of experts internally and in the larger machine learning (ML) and GenAI community to identify security risks to AI systems and define the controls necessary to mitigate those risks. The result is the **Databricks AI Security Framework (DASF)** which provides robust AI security guidelines and actionable defensive control recommendations to help organizations address the evolving risks associated with the global adoption of AI. The DASF development involved a thorough review of multiple risk management frameworks, recommendations, whitepapers, policies and AI security acts.

Accordingly the DASF provides a common language among business, data, security, privacy and governance teams to help demystify AI by breaking down components, deployment models and risks. The Framework starts with a generic AI system in terms of its constituent components and works through generic system risks. By understanding the components, how they work together and the risk analysis of such architecture, an organization can get a jump start on determining risks in its specific AI system. The DASF also delivers defense-in-depth controls

to simplify AI risk management for your organization to operationalize and can be applied to your chosen data and AI platform.

These seven steps, aligned with the DASF, provide a structured approach for organizations to identify, assess and mitigate AI risks — ensuring AI innovation remains secure, responsible and aligned with business goals.

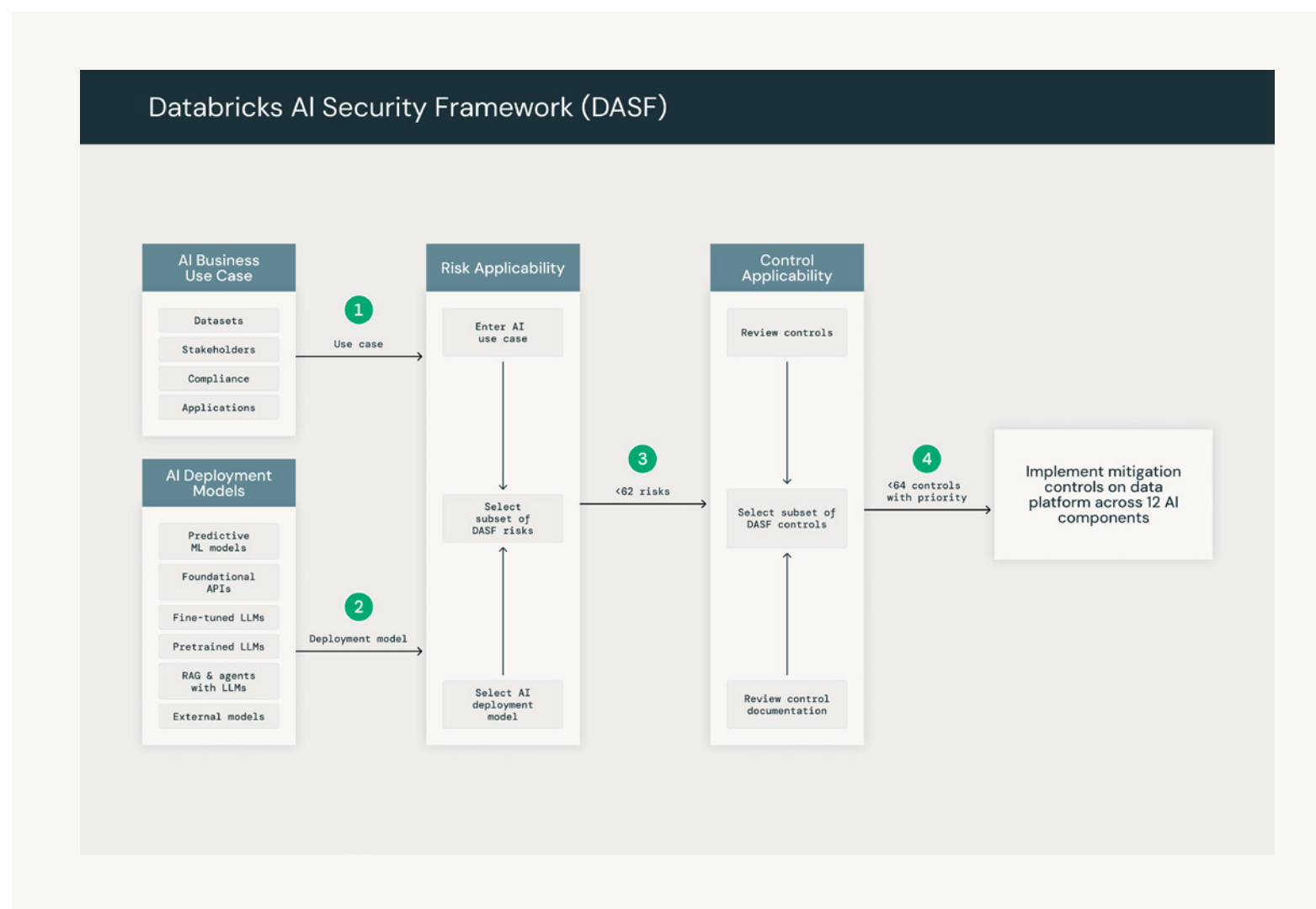


Figure 1: Implementation guidance of DASF controls on a data platform

Have a mental model of an AI system

To appreciate the unique risks associated with AI, it helps to understand the components that make up an AI system and how they work together. AI systems are comprised of data, code and models with architecture components that can be broadly categorized into four major stages:

- I Data operations** consist of ingesting and transforming data and ensuring data security and governance. Good ML models depend on reliable data pipelines and secure infrastructure.
- II Model operations** include building custom models, acquiring models from a model marketplace or using SaaS LLMs (like OpenAI). Developing a model requires a series of experiments and a way to track and compare the conditions and results of those experiments.

- III Model deployment and serving** consists of securely building model images, isolating and securely serving models, automated scaling, rate limiting and monitoring deployed models.

- IV Operations and platform** include platform vulnerability management and patching, model isolation and system controls and authorized access to models with security in the architecture. This step also consists of operational tooling for CI/CD. It ensures that the complete lifecycle meets the required standards by keeping distinct execution environments — development, staging and production — for secure MLOps.

Within those four stages, there are 12 foundational components of a generic AI system.



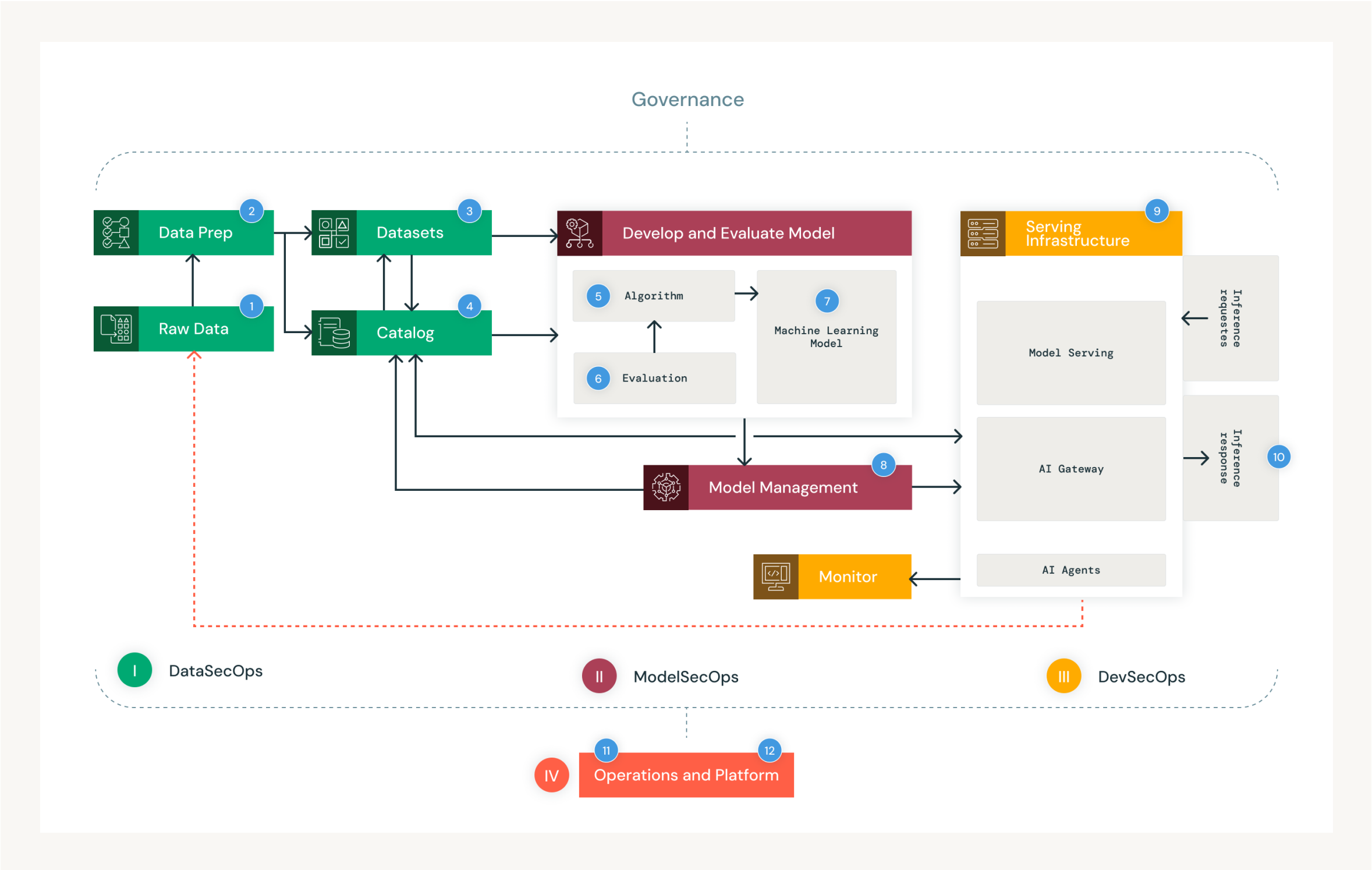


Figure 2: Foundational components of a generic data-centric AI system

In the **data operations** step, there are four components:

- **Raw data**, which includes enterprise data, metadata and operational data, provides the foundation that AI is built on. It can be batch or streaming data and includes semi-structured or structured data.
- **Data prep** occurs when raw input data is transformed into a representational form that machine learning algorithms can understand. This process includes cleaning, formatting, preprocessing, combining, labeling, validating and visualizing data.
- **Datasets** represent the prepared data which is grouped into a training set as the input, a validation set to tune hyperparameters and a testing set to evaluate performance.
- **Data catalog and governance** is a comprehensive approach to managing an organization's data assets throughout their lifecycle to enable centralized access control, auditing, lineage and data and model discovery.

The **model operations** step includes 4 important components:

- **Machine learning (ML) algorithms** are optimized during training to find certain patterns or outputs from the dataset, depending on the task. They process data offline (trained on a fixed dataset) and online (constantly exposed to new data).
- **Evaluation** is the process of assessing the effectiveness of an ML system in achieving its intended functionalities. It uses dedicated datasets to systematically analyze the performance of a trained model on its specific task.
- **Machine learning models** are programs that are trained to find patterns or make decisions from a previously unseen dataset, depending on the task.
- **Model management** requires a centralized "AI inventor" to develop, track, discover, govern, encrypt and access models with proper security controls.

The **model deployment and serving** step consists of two main components:

- **Model serving and inference requests** expose fully trained machine learning models as scalable REST API endpoints for inference and provide a highly available and low-latency service for deploying models.
- **Model serving and inference response** represent the real-world manifestation of the model's learning knowledge and form the basis for its decision-making capabilities.

The **operations and platform** step includes two key components:

- **Machine learning and operations (MLOps)** is the core function of machine learning engineering, focused on streamlining the process of taking machine learning models to production and then maintaining and monitoring them.
- **Data and AI platform security** helps prevent attacks on ML-driven systems. The platform used for building and deploying AI can have inherent risks.

Understand the people and processes involved

It's also important to understand where in the organization AI systems are being built and maintained, the process and who's responsible for ensuring collaboration and accountability throughout the AI lifecycle. Modern AI system lifecycles involve diverse stakeholders across business, governance, technology and data teams.

It can be tempting to extrapolate legacy processes designed for (deterministic) pre-AI systems and attempt to apply them to (probabilistic) AI systems. For most organizations, this will not lead to success.

Some key questions to consider:

- Who are the key stakeholders who need to be better aligned?
- Is there a unified enterprise-wide process to securely deploy new AI use cases?
- Are there multiple paths for deploying AI use cases that are commensurate with inherent risk?
- Are there defined criteria for prioritizing AI use cases?

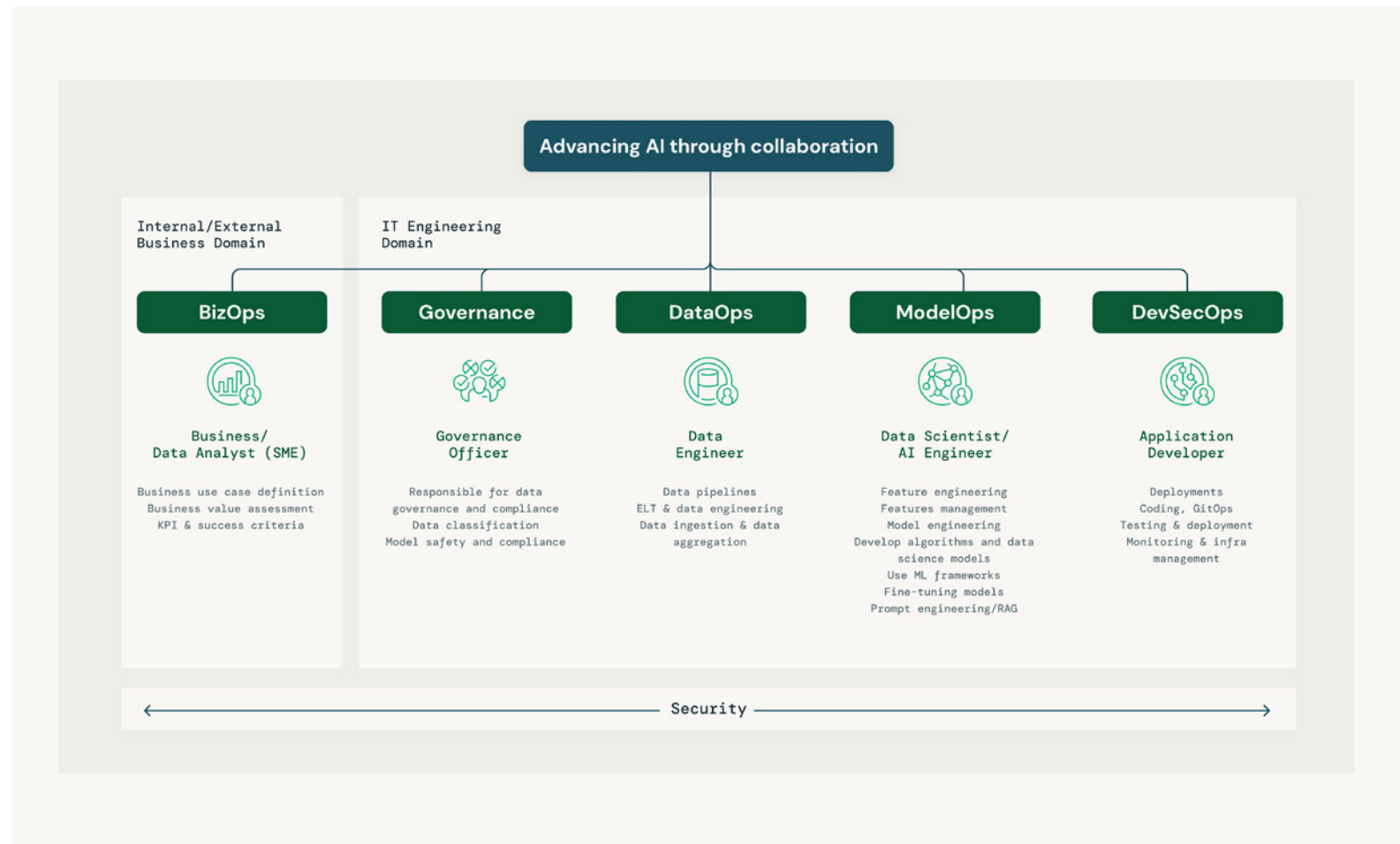


Figure 3: Stakeholders of modern AI lifecycle management and development

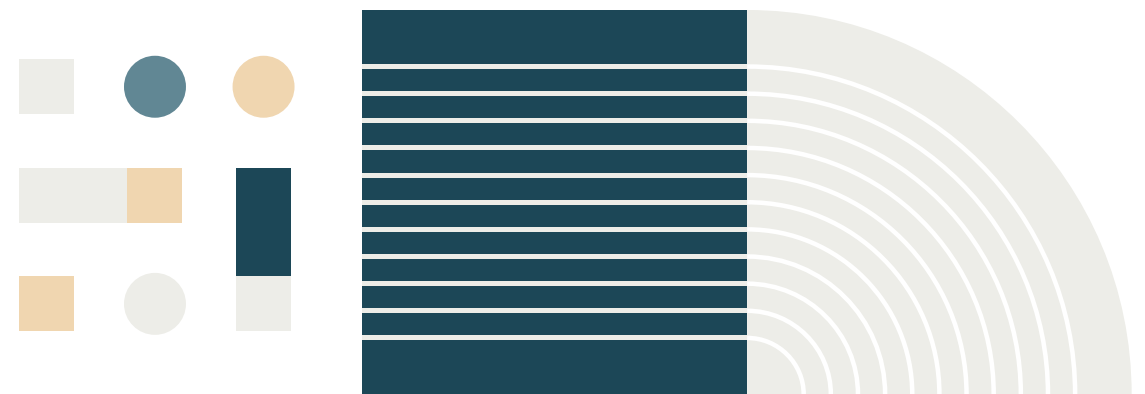
Understand AI security risks

To effectively secure AI systems, organizations must first develop a clear understanding of the risks involved. Unlike traditional IT security, AI introduces new vulnerabilities that span data, models, infrastructure and governance. In the DASF, we identified 62 distinct risks across the 12 components of an AI system, highlighting the complex and evolving nature of AI security. At a high level, these risks include:

- Data Operations: There are **20 specific risks**, such as insufficient access controls, missing data classification, poor data quality, lack of data access logs and data poisoning.
- Model operations: There are **15 specific risks**, such as experiments not being tracked and reproducible, model drift, stolen hyperparameters, malicious libraries and evaluation data poisoning.
- Model deployment and serving: There are **19 specific risks**, such as prompt injection, model inversion, denial of service (DOS), LLM hallucinations and black-box attacks.
- Operations and platform: There are **8 specific risks**, such as a lack of vulnerability management, penetration testing and bug bounty, unauthorized privileged access, a poor software development lifecycle (SDLC) and compliance.

A note on responsible AI

Adopting AI raises regulatory considerations, exemplified by evolving U.S. federal government mandates, the EU AI Act and over 120 additional countries with AI-related laws, underscoring the importance of responsible governance and oversight. Many of the risks associated with AI may, on the surface, seem unrelated to cybersecurity (e.g., fairness, transparency, reliability) but cybersecurity teams can play an important role in deploying the controls (e.g., authentication, access controls, logging, data lineage, monitoring, auditing) needed to enforce the responsible use of AI.



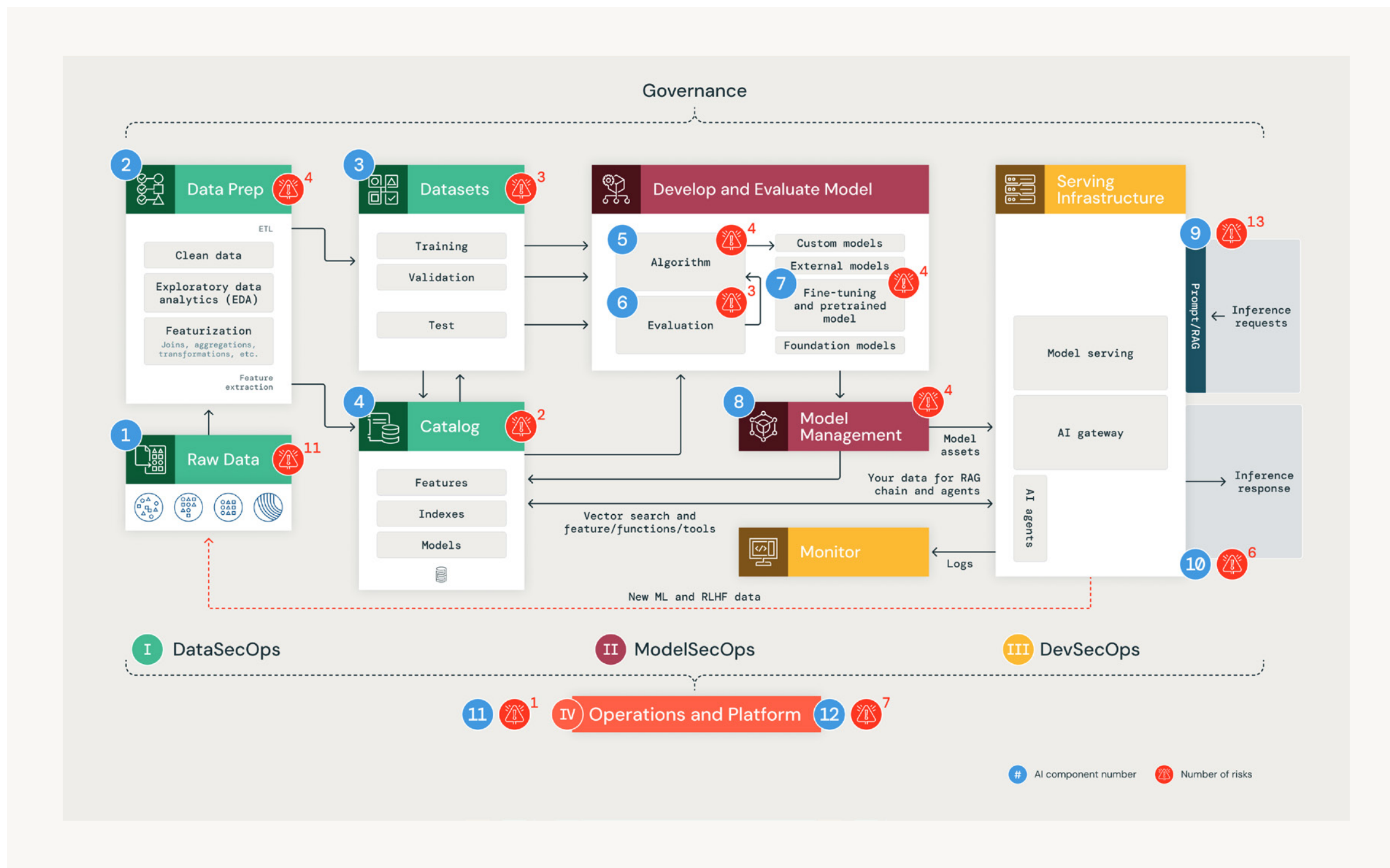


Figure 4: Foundational components of a generic data-centric AI system with risk mapping

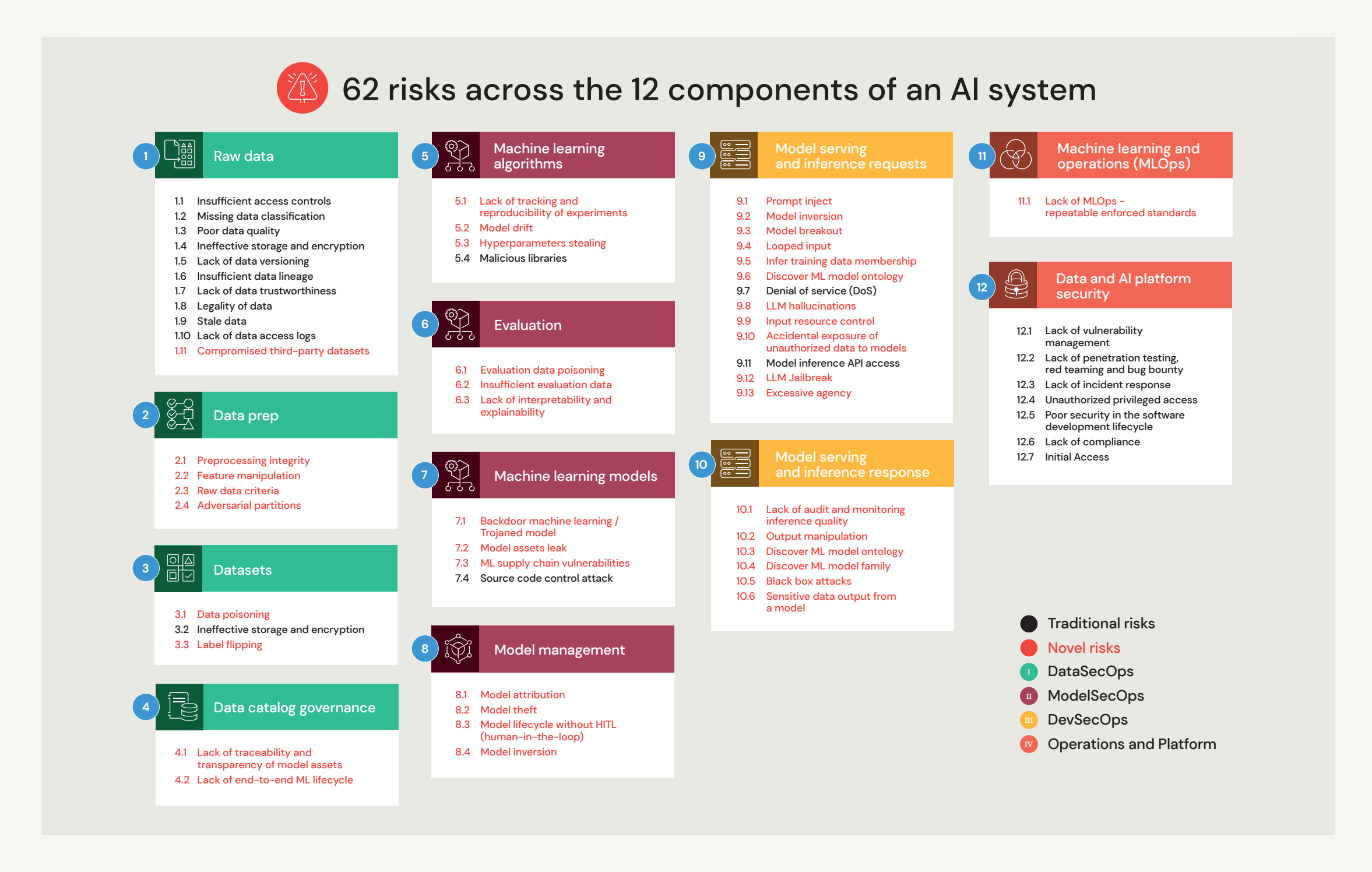


Figure 5: 62 Traditional and novel risks across the 12 components of an AI system. For a detailed breakdown of these risks, download the [Databricks AI Security Framework](#)

Understand AI use cases and deployment models

To understand how best to protect your AI systems, first, find out what type of AI use cases apply to your organization and the type of deployment models being implemented. Use cases may range from generative AI, computer vision, natural language processing, predictive analytics, recommendations, decisioning, etc. We recommend leveraging the Databricks Solution Accelerators to speed up your AI-driven outcomes with purpose-built guides for a range of industries and use cases.

You'll also need to define the deployment model type for each of your use cases. Deployment models can be broadly defined as the following:

- **Predictive ML models:** These are traditional structured data machine learning models trained on your enterprise tabular data.
- **Frontier models** are made available by foundation model APIs: These models are curated foundation model architectures that support optimized inference. We subcategorize their usage patterns as the following:

Foundation Model LLMs: Large-scale AI models trained on vast amounts of data to develop broad language understanding and generation capabilities. They can be adapted for specific tasks through fine-tuning or prompting, making them highly versatile across various applications.

Retrieval augmented generation (RAG) LLMs: These models improve response accuracy by dynamically retrieving relevant external data rather than relying solely on pre-trained knowledge. This approach enhances contextual relevance, reduces hallucinations, and allows models to incorporate the most up-to-date information.

Pre-trained LLMs: Large language models trained on extensive datasets to develop a broad understanding of language patterns, grammar, and knowledge. They can be fine-tuned or adapted for specific tasks, enabling efficient and accurate performance across various applications.

Fine-tuned LLMs: Pretrained language models model that have been further trained on domain-specific data to improve their performance for specialized tasks. This process enhances their accuracy, relevance and ability to generate contextually appropriate responses in targeted applications.

- **External models:** These are third-party models that are hosted outside of Databricks. Endpoints that serve external models can be centrally governed, and customers can establish rate limits and access controls for them. Examples include foundation models such as OpenAI's GPT, Anthropic's Claude and others.
- **Agentic AI:** Agentic AI systems integrate multiple AI models, tools, and pipelines for greater performance, versatility and reusability than standalone models. AI-forward organizations use them to build complex solutions, such as RAG applications with agent frameworks, which combine models with enterprise data enrichment.

Many companies have already taken the initial step of unifying metadata for their data and AI assets in one location or catalog to eliminate redundancies and improve data integrity. As enterprises deploy more AI use cases, this will serve as a critical foundation. Governing the two together ensures that AI models are generating outputs and taking action based on high-quality datasets. This improves the overall performance of the AI system, while also reducing the operational costs involved with building and maintaining it.

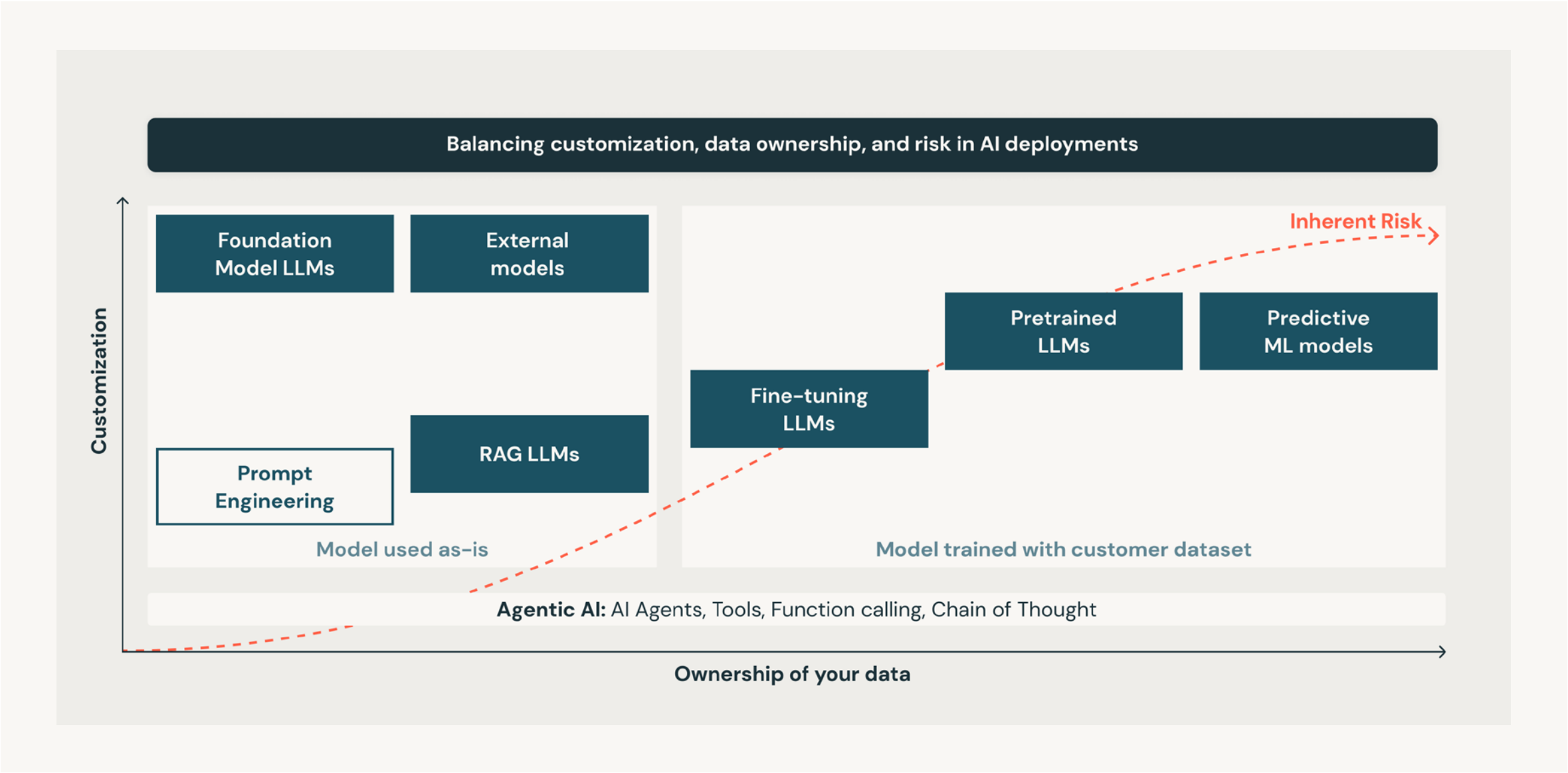


Figure 6: Customization of AI with your data

Understand the unique threats for your AI use cases

Not every security threat will apply to your particular use cases. An organization's risks depend on factors such as the type of AI models deployed, the data it uses, and the industry-specific regulatory landscape. In the DASF, we map the 62 risks to leading industry AI risk frameworks and standards such as MITRE ATLAS, OWASP LLM & ML Top 10, NIST CSF and the EU AI Act.

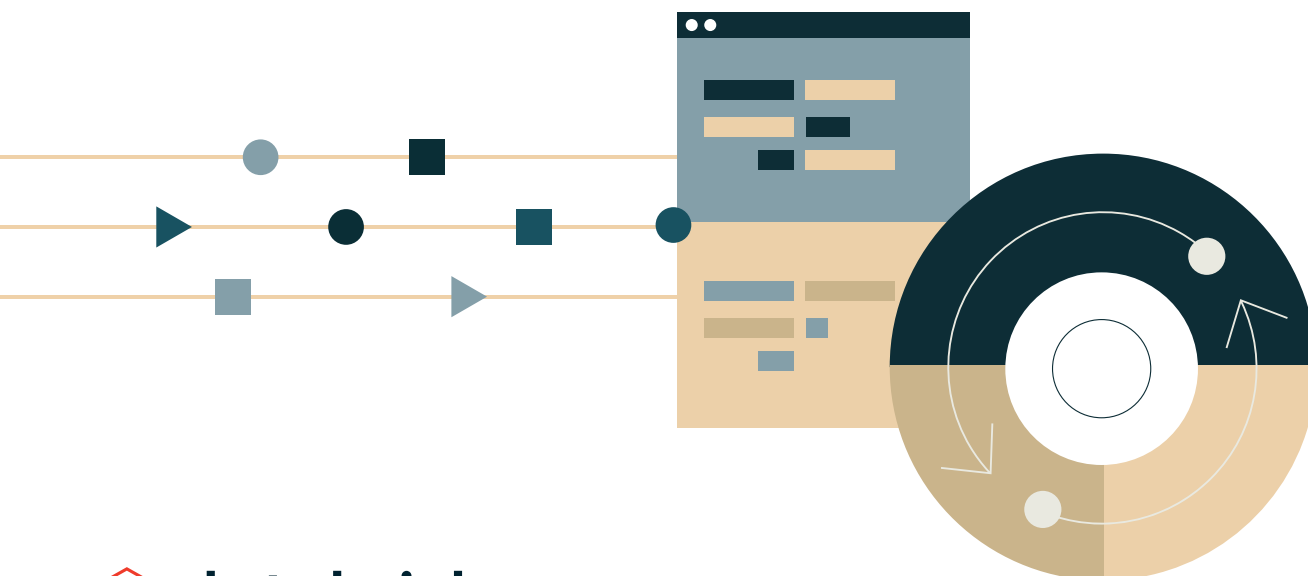
Rather than trying to solve all possible threats and getting bogged down analyzing all the possible worst-case scenarios, first, identify the threats that are relevant to your AI use cases based on the DASF risks and framework(s) most relevant to your organization, industry and geography. This targeted approach allows teams to focus on mitigating the most pressing threats, ensuring a balanced, efficient risk management strategy that enables AI innovation without unnecessary roadblocks.

Understand the unique risks based on your use cases

Just as not all threats will apply to your AI systems, not every security risk outlined above will be relevant to your specific use cases and deployment models. To effectively assess and mitigate risks, start by documenting key details about your AI use case — including its purpose, datasets, stakeholders, compliance requirements and applications.

To streamline this process, we've introduced the DASF Compendium, which is a structured worksheet designed to help organizations determine which risks, threats and controls apply to their AI use cases. This resource maps AI security risks to deployment models, datasets and stakeholders while aligning with industry-recognized standards from MITRE, OWASP, NIST, ISO, HITRUST and more.

Additionally, to provide a deeper understanding of risk impact, we've categorized each of the 62 technical security risks using the FAIR risk methodology, outlining both primary and secondary loss scenarios. This structured approach helps teams prioritize risks effectively, ensuring AI security strategies align with broader business and compliance objectives.



Identify and implement risk mitigation controls

Once your teams have identified the risks relevant to your AI use cases and model types, the DASF provides 64 platform-agnostic risk mitigation controls, mapped across the 12 AI components and 62 technical security risks. These controls help organizations establish a proactive AI security posture while aligning with industry standards.

For organizations using Databricks, we've also included references to documentation within the Databricks ecosystem to help operationalize these controls effectively. To strengthen AI security, teams should integrate these controls with existing organizational policies and ensure proper oversight.

As a starting point, we recommend prioritizing these **12 key risk mitigations**:

- 1 Authenticate and authorize** access to your data.
- 2 Automate and quality check** data before feeding it into model training.
- 3 Govern, version and tag** your data while tracking lineage.
- 4 Encrypt data** with your own keys at rest and in transit.
- 5 Enforce approval workflows** to prevent models from being trained on unintended data sources.
- 6 Track model artifacts, datasets, versions and stakeholders** for trust, explainability and responsibility.
- 7 Automate testing loss analysis** after (re)training by evaluating model behavior on specific test inputs.
- 8 Encrypt, authenticate and authorize** models and endpoints while logging, auditing and monitoring access.
- 9 Segregate LLMs and other models** from internal and external systems.
- 10 Implement MLOps with HITL** by enforcing permissions, versions, tags, ownership and approvals for production models.
- 11 Host models behind a gateway** to rate limit safety filtering, personally identifiable information (PII) detection, topic moderation and keyword filtering.
- 12 Audit and monitor data and model access** at every stage of the model lifecycle.

By applying these foundational mitigations, organizations can build secure, resilient and aligned AI systems with business objectives while mitigating evolving threats in an increasingly AI-driven world.

